

[0] ĐỌC CODE TRƯỚC (bắt buộc)

bash

```
find . -type f \( -name "*.js" -o -name "*.ts" \) | grep -v node_modules | sort
cat package.json
cat src/index.js 2>/dev/null || cat src/app.js 2>/dev/null || cat src/server.js
ls src/routes/ && cat src/routes/*.js 2>/dev/null | head -200
cat src/controllers/*.controller.js 2>/dev/null | head -200
cat src/config/db.js 2>/dev/null || cat src/database/connection.js
cat src/utlis/response.js 2>/dev/null || cat src/helpers/response.js
cat src/middlewares/auth.middleware.js 2>/dev/null || cat src/middlewares/auth.js
```

→ Ghi nhớ: framework, ORM/raw-query, response format, auth middleware, file naming convention.

[1] CONVENTIONS (áp dụng toàn bộ)

- **Response:** {success:bool, data?, message?, pagination?}
- **Pagination:** params page(def:1) + limit(def:20) → {current_page, per_page, total_items, total_pages}
- **Auth:** Bearer JWT → req.user = {user_id, roles:string[]}
- **Seller store:** SELECT store_id FROM user_stores WHERE user_id=@uid AND store_member_role='OWNER' AND is_active=1
- **Soft delete:** set deleted_at=SYSUTCDATETIME() hoặc status='INACTIVE'
- **SQL Server:** dùng @param, OFFSET x ROWS FETCH NEXT y ROWS ONLY
- **Comment code:** tối thiểu — chỉ comment logic không tự giải thích được

GROUP 16: Admin (55–62)

Auth: Admin hoặc Manager (trừ chú thích riêng)

55 · List All Users GET /api/v1/admin/users | Admin, Manager

Params: role_code?, status?, keyword?, page, limit

sql

```
SELECT u.user_id, u.email, u.phone, u.full_name, u.status, u.created_at,
       STRING_AGG(r.role_code, ',') AS roles
FROM users u
LEFT JOIN user_roles ur ON ur.user_id=u.user_id AND ur.status='ACTIVE'
LEFT JOIN roles r ON r.role_id=ur.role_id
WHERE u.deleted_at IS NULL
      [AND r.role_code=@rc] [AND u.status=@s] [AND (u.email LIKE @kw OR u.full_name LIKE @kw)]
```

```
GROUP BY u.user_id, u.email, u.phone, u.full_name, u.status, u.created_at
ORDER BY u.created_at DESC
```

→ 200:

```
{users:[{user_id,email,phone,full_name,status,roles[],created_at}],
pagination}
```

56 · Update User Status **PATCH** /api/v1/admin/users/:id/status | Admin only

Body: {status(ACTIVE|SUSPENDED)}

- Không tự suspend mình: `id != token.user_id`

→ 200: {user_id, status} | 400 | 403 | 404

57 · Assign Role **POST** /api/v1/admin/users/:id/roles | Admin only

Body: {role_code}

- Check role tồn tại
- Check chưa có: `UX_user_roles_user_role(user_id, role_id)` → 409
- INSERT user_roles (assigned_by_user_id=@uid, status='ACTIVE')

→ 201: {user_id, role_code} | 409 | 404

58 · List All Stores **GET** /api/v1/admin/stores | Admin, Manager

Params: status?, keyword?, page, limit

sql

```
SELECT s.store_id, s.store_name, s.slug, s.status, s.total_products, s.created_at,
       u.full_name AS owner_name, u.email AS owner_email
FROM stores s
JOIN user_stores us ON us.store_id=s.store_id AND us.store_member_role='OWNER' AND
us.is_active=1
JOIN users u ON us.user_id=u.user_id
WHERE s.deleted_at IS NULL [AND s.status=@s] [AND s.store_name LIKE @kw]
ORDER BY s.created_at DESC
```

→ 200: {stores[], pagination}

59 · Update Store Status **PATCH** /api/v1/admin/stores/:id/status | Admin only

Body: {status(ACTIVE|INACTIVE|SUSPENDED)}

→ 200: {store_id, status} | 403 | 404

60 · List All Orders GET /api/v1/admin/orders | Admin, Manager

Params: status?, store_id?, customer_id?, from_date?, to_date?, page, limit

sql

```
SELECT o.order_id, o.order_code, o.order_status, o.total_amount, o.created_at,
       u.full_name AS customer_name, s.store_name
FROM orders o
JOIN users u ON o.customer_id=u.user_id
JOIN stores s ON o.store_id=s.store_id
WHERE 1=1
      [AND o.order_status=@s] [AND o.store_id=@sid] [AND o.customer_id=@cid]
      [AND o.created_at >= @from] [AND o.created_at <= @to]
ORDER BY o.created_at DESC
```

→ 200: {orders[], pagination}

61 · Revenue Report GET /api/v1/admin/revenue | Admin, Manager

Params: from_date(req), to_date(req), group_by(day|store, def:day), store_id? Chỉ tính order_status='COMPLETED'

group_by=day:

sql

```
SELECT CAST(o.created_at AS DATE) AS date,
       COUNT(*) AS order_count, SUM(o.total_amount) AS revenue
FROM orders o
WHERE o.order_status='COMPLETED' AND o.created_at BETWEEN @from AND @to
      [AND o.store_id=@sid]
GROUP BY CAST(o.created_at AS DATE) ORDER BY date ASC
```

group_by=store: GROUP BY o.store_id, s.store_name

→ 200: {from_date, to_date, group_by, total_revenue, total_orders, data:[{date|store_name, order_count, revenue}]}

62 · Assign Shipper POST

/api/v1/admin/shipments/:orderId/assign | Admin only

Body: {shipper_user_id}

- Check order.order_status = 'READY_TO_SHIP' → 400 nếu không

- Check user có role_code='SHIPPER' → **400** nếu không
- Lấy shipment theo order_id (đã tạo ở API #40)
- `UPDATE shipments SET shipper_user_id=@sid, shipment_status='ASSIGNED', assigned_at=NOW()`

→ **200**: {shipment_id, shipper_user_id, shipment_status:'ASSIGNED'} | **400**
| **404**

CHECKLIST:

- [] Tất cả 8 route (55-62) đăng ký đúng router.
- [] Auth middleware phân quyền cấp cao: 'Admin' và 'Manager' tùy từng API cụ thể.
- [] An toàn bảo mật: Đảm bảo Admin không tự khóa tài khoản của chính mình (API 56).
- [] Parameterized query (Cực kỳ lưu ý với các bộ lọc `[AND condition]` ở các API báo cáo/list để tránh SQL Injection).
- [] Partial update: Chỉ SET status (API 56, 59).
- [] Response format nhất quán.